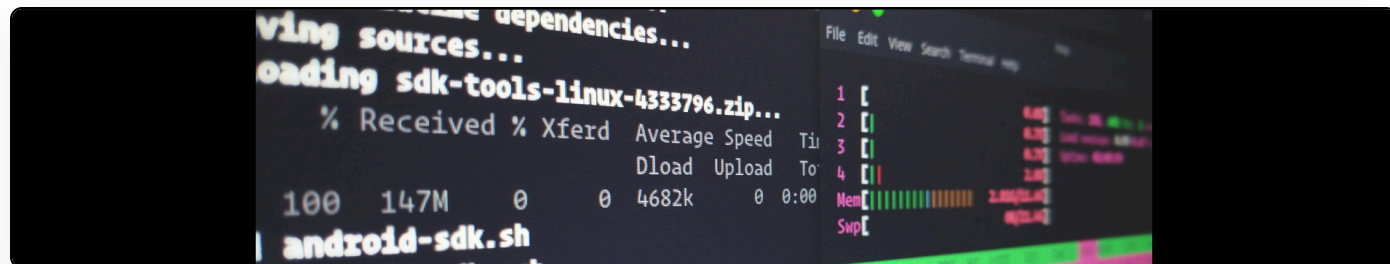


CSRF being used in latest IPB vuln – what about PHP web request?

Cite as: Martin Paul Eve, "CSRF being used in latest IPB vuln – what about PHP web request?", *eve.gd: Martin Paul Eve*, June 19, 2007, <https://doi.org/10.59348/jr7ny-stf90>.



I was interested to see in a XSS/CSRF exploit the following lines:

```
if(preg_match("/ipb_admin_session_id=([0-9a-z]{32});/", $data, $stuff))
{
    print '</img>';
}
```

This is obviously designed to be included in a PHP script which should then be included as part of a XSS attack and causes a CSRF attack on IPB to promote a user to administrator status. However, I then got thinking of a far smarter way to perform this type of attack:

1. User visits site including XSS vuln
2. XSS vuln loads malicious site in an iframe with Cookie Data
3. PHP/.NET page receives malicious input and issues its own socket request to take actions on the site

This approach is far better than just logging cookies because, obviously, cookies can expire. In this methodology the user can be impersonated at the instant they suffer the XSS vulnerability. Furthermore, the power of sockets/WebRequests means that the User Agent could be impersonated. Obviously this approach does not maintain the IP address of the victim, but then again, that is a flawed methodology for securing CSRF vulns. My personal feeling is that for sophisticated attacks this is a far more subtle approach.